CAPACITACIÓN TÉCNICA · BANCO DE MÉXICO

# Desarrollo Seguro de Sistemas

## Módulo 1 · Introducción al OWASP Top 10:2025




50 diapositivas · Conceptos, contexto financiero y actividades de análisis

**Java JDK 17 | Jakarta EE 11 | PostgreSQL 16**

Instructor: Juan Carlos Trejo Herrera · Material de apoyo

# Módulo 1. Introducción al OWASP Top 10:2025

Desarrollo Seguro de Sistemas (OWASP)

Banco de México · Capacitación técnica

Java JDK 17 · Jakarta EE 11 · PostgreSQL 16

**CASO BANCARIO HIPOTÉTICO**

Material de apoyo para el instructor Juan Carlos Trejo Herrera

# Cómo se verá el enfoque práctico

Observar un comportamiento de aplicación.

Identificar el riesgo y su posible causa raíz.

Reproducir el escenario en un entorno controlado.

Proponer y aplicar una corrección.

Volver a probar para comprobar el resultado.

### Ciclo de trabajo

- OBSERVAR → IDENTIFICAR → CORREGIR → VALIDAR

**CASO BANCARIO HIPOTÉTICO**

Se simulará una consulta de operación con datos sintéticos; nunca se utilizarán datos ni sistemas reales del Banco de México.

# Lenguaje común: cuatro conceptos

Activo: aquello que se necesita proteger.

Amenaza: circunstancia o actor capaz de causar daño.

Vulnerabilidad: debilidad que puede ser aprovechada.

Riesgo: combinación contextual de probabilidad y consecuencias.

**Distinción clave**

- Activo ≠ amenaza ≠ vulnerabilidad ≠ riesgo



**CASO BANCARIO HIPOTÉTICO**

Activo: detalle de una operación financiera; amenaza: acceso no autorizado; vulnerabilidad: autorización insuficiente; riesgo: exposición o modificación de información.

# ¿Qué significa OWASP?

Open Worldwide Application Security Project (OWASP).

Comunidad abierta dedicada a mejorar la seguridad del software.

Facilita recursos para desarrollar, adquirir y mantener aplicaciones y API confiables.

Su trabajo combina educación, herramientas, investigación y colaboración.

**Idea central**

- Comunidad abierta para mejorar la seguridad de aplicaciones




**CASO BANCARIO HIPOTÉTICO**

Un equipo de desarrollo puede consultar guías abiertas de OWASP para revisar cómo proteger un endpoint de consulta financiera.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# OWASP: comunidad, no producto comercial

OWASP no es un fabricante de una plataforma única de seguridad.

Sus proyectos se desarrollan de forma colaborativa y transparente.

La Fundación OWASP sostiene la continuidad de la comunidad y sus proyectos.

La independencia comercial favorece recursos prácticos e imparciales.

**Para recordar**

- OWASP ofrece conocimiento y proyectos; no certifica automáticamente una aplicación.




**CASO BANCARIO HIPOTÉTICO**

La institución puede estudiar una guía OWASP sin que ello implique comprar una herramienta o contratar un proveedor específico.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# Qué recursos ofrece OWASP

Herramientas y estándares de seguridad de aplicaciones.

Investigación, libros, presentaciones y videos.

Guías de referencia rápida y controles de seguridad.

Proyectos comunitarios, capítulos, eventos y formación.

**Recursos abiertos**

- Documentación
- herramientas
- formación
- comunidad

**CASO BANCARIO HIPOTÉTICO**

Para revisar un hallazgo en una API financiera, el equipo puede contrastar el comportamiento observado con material técnico abierto de OWASP.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# La seguridad requiere personas, procesos y tecnología

Personas: conocimientos, responsabilidades y colaboración.

Procesos: diseño, revisión, pruebas, respuesta y mejora.

Tecnología: código, plataformas, herramientas y controles.

Una herramienta no sustituye decisiones de diseño ni prácticas consistentes.

**Tres dimensiones**

- PERSONAS + PROCESOS + TECNOLOGÍA



**CASO BANCARIO HIPOTÉTICO**

Un escáner puede detectar una respuesta anómala, pero el equipo debe entender la regla de negocio y corregir el control en la aplicación.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# ¿Qué es OWASP Top 10?

Es un documento de concientización sobre los riesgos de seguridad más críticos en aplicaciones web.

Representa un amplio consenso de la comunidad.

Agrupa debilidades en categorías de riesgo para facilitar su comprensión y priorización.

La edición 2025 es la octava edición del proyecto.

**Definición**

- Documento de concientización; no catálogo exhaustivo de fallas.




**CASO BANCARIO HIPOTÉTICO**

Puede ayudar a organizar una conversación sobre riesgos de una aplicación de consulta de operaciones, antes de definir pruebas específicas.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# Qué no es el Top 10

No es una lista completa de todas las vulnerabilidades posibles.

No es una garantía de que una aplicación sea segura si no presenta esas categorías.

No es, por sí solo, una norma de certificación o una lista de cumplimiento.

No sustituye el análisis de riesgos propio de cada organización.

**Advertencia**

- No convertir el Top 10 en una lista de verificación suficiente por sí sola.



**CASO BANCARIO HIPOTÉTICO**

Que una aplicación financiera no tenga hallazgos clasificados en A01–A10 no demuestra que esté libre de todos los riesgos.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# Riesgo, vulnerabilidad y categoría no son sinónimos

Una vulnerabilidad es una debilidad concreta en un componente o proceso.

Una categoría agrupa debilidades relacionadas bajo un riesgo común.

El riesgo depende del contexto, la exposición y el impacto.

Un mismo hallazgo puede requerir análisis adicional para determinar su causa raíz.

**Ejemplo**

- Hallazgo técnico → causa raíz → categoría → impacto contextual



**CASO BANCARIO HIPOTÉTICO**

Una consulta sin autorización adecuada es un hallazgo técnico; su clasificación puede relacionarse con A01 y su impacto dependerá de los datos y privilegios expuestos.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# El Top 10 no reemplaza el análisis de impacto

La clasificación OWASP ofrece una perspectiva general.

La organización debe valorar sus propios activos y procesos.

La prioridad debe considerar exposición, probabilidad, controles e impacto.

La decisión de tratamiento debe documentarse y revisarse.

**Aplicación**

- Categoría OWASP + contexto institucional = evaluación útil



**CASO BANCARIO HIPOTÉTICO**

Un hallazgo en una función de conciliación requiere analizar si podría alterar resultados, retrasar procesos o afectar la confianza en los datos.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# Cómo utilizarlo en el trabajo cotidiano

Capacitación y sensibilización de equipos de desarrollo.

Apoyo para revisar código y discutir patrones inseguros.

Orientación para diseñar casos de prueba y pruebas de seguridad.

Clasificación y comunicación de hallazgos y acciones de remediación.

**Uso sugerido**

- Convertir cada categoría en preguntas verificables.




**CASO BANCARIO HIPOTÉTICO**

El equipo revisa un endpoint REST y utiliza A01 como lente para preguntar quién puede consultar, modificar o eliminar cada recurso.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# Por qué importa la causa raíz

OWASP busca orientar la atención hacia causas raíz cuando es posible.

Los síntomas pueden aparecer en diferentes categorías o contextos.

La causa raíz permite elegir una remediación más sostenible.

La clasificación facilita aprendizaje, pero no sustituye el diagnóstico técnico.

**Para discutir**

- ¿Qué cambia si corregimos el síntoma, pero no la causa?



**CASO BANCARIO HIPOTÉTICO**

Un error visible en pantalla podría ser síntoma; la causa real puede estar en una configuración, un control de acceso o el manejo de excepciones.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# Una lista que evoluciona

El Top 10 se publica desde 2003.

La edición 2025 es la octava edición.

Cada revisión incorpora datos, análisis y aportaciones de la comunidad.

Las categorías reflejan cambios en tecnologías, prácticas y amenazas.

**Mensaje clave**

- El riesgo cambia; la referencia debe revisarse.




**CASO BANCARIO HIPOTÉTICO**

Una aplicación financiera moderna puede depender de más bibliotecas, servicios y procesos automatizados que una aplicación monolítica antigua.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# De 2003 a 2025: ocho ediciones

2003 · primera publicación.

2004, 2007, 2010, 2013, 2017 y 2021 · revisiones sucesivas.

2025 · octava edición.

La evolución no significa que los riesgos anteriores desaparezcan.

**Lectura de la historia**

- Cambio de posición ≠ desaparición del riesgo.




**CASO BANCARIO HIPOTÉTICO**

Un equipo no debe abandonar controles de inyección solo porque A05 pasó de una posición anterior al quinto lugar en 2025.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# CWE: las debilidades detrás de las categorías

CWE significa Common Weakness Enumeration.

Una categoría OWASP agrupa varias debilidades relacionadas.

Las CWE describen tipos de debilidad más específicos que una categoría amplia.

Una categoría no equivale necesariamente a una sola vulnerabilidad o a un solo CWE.

**Relación**

- CWE = debilidad específica
- Top 10 = categoría de riesgo

**CASO BANCARIO HIPOTÉTICO**

Un hallazgo en una API puede relacionarse con una CWE concreta y, tras analizar su causa, mapearse a A01.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# Las diez categorías, en una sola vista

A01 · Pérdida de Control de Acceso

A02 · Configuración de Seguridad Incorrecta

A03 · Fallas en la Cadena de Suministro de Software

A04 · Fallas Criptográficas

A05 · Inyección

**A01–A05**

- Control de acceso
- configuración
- cadena de suministro
- criptografía
- inyección

**CASO BANCARIO HIPOTÉTICO**

Estas primeras cinco categorías se revisarán con ejemplos financieros hipotéticos y se profundizarán en los módulos posteriores.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# Las diez categorías, en una sola vista (continuación)

A06 · Diseño Inseguro

A07 · Fallas de Autenticación

A08 · Fallas en la Integridad del Software o de los Datos

A09 · Fallas en el Registro, Alerta y Monitoreo de Seguridad

A10 · Manejo Inadecuado de Condiciones Excepcionales

**A06–A10**

- Diseño
- autenticación
- integridad
- alertas
- excepciones

**CASO BANCARIO HIPOTÉTICO**

Estas categorías abarcan decisiones de diseño, identidad, integridad, detección y comportamiento ante situaciones anormales.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# Lo que debe quedar claro

OWASP es una comunidad abierta que publica recursos para mejorar la seguridad de aplicaciones.

Top 10:2025 es un documento de concientización, no una lista exhaustiva ni una certificación.

La edición combina datos y encuesta comunitaria; sus indicadores describen una población analizada.

Las diez categorías ofrecen un lenguaje común para reconocer riesgos y orientar el análisis.

### Siguiente paso

- Pasar de reconocer el riesgo a reproducirlo, corregirlo y validarlo.



**CASO BANCARIO HIPOTÉTICO**

En los siguientes módulos, cada categoría se conectará con ejemplos de código Java/Jakarta y ejercicios sobre la aplicación didáctica.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.

# Comprobación rápida de aprendizaje

¿Cuál es la diferencia entre una vulnerabilidad y una categoría de riesgo?

¿Por qué OWASP Top 10 no debe tratarse como una certificación o checklist exhaustivo?

¿Qué aporta combinar datos de pruebas y encuesta comunitaria?

**Autoevaluación**

- Responde en voz alta o en el chat; justifica con evidencia.



**CASO BANCARIO HIPOTÉTICO**

En una plataforma financiera hipotética, justifica tu clasificación con el activo afectado, la debilidad observada y el impacto posible.

Referencia: OWASP Top 10:2025, documentación oficial en español; propuesta validada y sesión de alineamiento.